

Desarrollo seguro y seguridad del código

SYN-MON-SEC-ES | sección=S00 | idioma=es | versión=1.0 | fictional=true

Etiquetas: SSDLC; AppSec; código; vulnerabilidades; cadena de suministro

MUESTRA FICTICIA

SOLO PARA PRUEBAS DE AUTOMATIZACIÓN DE RFP

S00.01 Propósito del documento

Ofrecer una política técnica ficticia, suficientemente estructurada para probar recuperación de controles, condiciones y evidencias en cuestionarios RFP de software bancario. El contenido define decisiones de diseño y procedimientos de ejemplo. No describe repositorios, herramientas instaladas, pruebas ejecutadas ni controles operativos reales de Montran.

S00.02 Delimitación de la ficción

El nombre Montran se utiliza únicamente como referencia solicitada para un escenario inventado. Ninguna entidad del escenario, práctica, obligación, cifra, evidencia, resultado o declaración constituye un hecho de Montran ni de sus afiliadas. Este archivo no procede de Montran, no acredita una relación comercial y no contiene una certificación, contrato, informe de auditoría o control verificado.

Campo de control	Valor del corpus
Identificador / colección	SYN-MON-SEC-ES / MONTRAN-RFP-SYNTH-ES-01
Versión / idioma / clasificación	1.0 / español (es) / contenido sintético
Fecha de escenario / creación	2026-10-01 / 2026-10-03; fechas sin vigencia jurídica
Responsable de ejemplo	Coordinación de seguridad de producto del escenario; función inventada, sin persona asignada
Validez probatoria	Ninguna. real_world_claims=false; certification_evidence=false

Alcance editorial: diseño, desarrollo, integración, revisión, construcción, despliegue y mantenimiento de un producto imaginario. Las metas y evidencias sirven solo para ensayos RAG/CAG; no certifican seguridad o efectividad.

Guía de lectura y recuperación

SYN-MON-SEC-ES | sección=S01 | idioma=es | versión=1.0 | fictional=true
Etiquetas: metadatos; índice; citas; alcance; segmentación

S01.01 Contrato de datos del corpus

Cada sección es una unidad temática; los apartados numerados pueden utilizarse como fragmentos. Conservar doc_id, section_id, chunk_id, versión, idioma, página, topic_id y fictional=true junto al texto. Los identificadores EV-* designan evidencias narrativas inventadas; no existen anexos probatorios emitidos por una empresa o auditor.

Sección y localizador	Contenido	Pág.
S00	Portada y límites de uso	1
S01	Guía de lectura y recuperación	2
S02	Alcance técnico y responsabilidades	3
S03	Requisitos y modelado de amenazas	4
S04	Identidades, accesos y secretos	5
S05	Codificación y revisión de cambios	6
S06	Pruebas y gestión de vulnerabilidades	7
S07	Dependencias y cadena de suministro	8
S08	Construcción y liberación controlada	9
S09	Protección de datos y trazabilidad	10
S10	Incidentes, recuperación y mejora	11
S11	Matriz RFP: diseño y desarrollo	12
S12	Matriz RFP: operación y remediación	13
S13	Pruebas RAG/CAG y evidencia ausente	14

Cita modelo: [SYN-MON-SEC-ES v1.0, S02.01, p. 3, FICTICIO]. Para responder sobre una empresa real, el resultado esperado es «No verificable con este corpus». Nunca transformar «propuesto» o «pendiente» en «implantado».

Vocabulario de estados: MODELO = diseño hipotético; CONDICIONADO = depende del supuesto indicado; NO CONSTA = información ausente; NO APLICA = fuera del alcance ficticio. Todo estado mantiene fictional=true.

Alcance técnico y responsabilidades

SYN-MON-SEC-ES | sección=S02 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=SEC_GOVERNANCE; SSDLC; roles; entornos; activos

S02.01 Producto y límites del supuesto

El escenario ficticio utiliza Plataforma Bancaria de Prueba P-01, integrada por una API, un servicio de procesamiento, una interfaz administrativa y una base de datos sintética. No se afirma que esta arquitectura corresponda a un producto de Montran. Se consideran entornos separados de desarrollo, validación y demostración; no existe una producción bancaria real documentada. Los controles propuestos deben evaluarse por activo, función, amenaza y etapa del ciclo de vida.

S02.02 Responsables y segregación

La persona que introduce un cambio de ejemplo no aprobaría por sí sola su liberación. Un responsable de producto definiría requisitos; el equipo de desarrollo implementaría; revisión técnica y seguridad examinarían los riesgos; operaciones ejecutaría el despliegue autorizado. La separación es un diseño ficticio y no demuestra dotación de personal. Si una función se acumulara, se requeriría un revisor independiente y un registro explícito de compensación.

Activo ficticio	Responsable de ejemplo	Registro narrativo
API y flujos de negocio	Responsable de producto	EV-S02-A: inventario
Código y dependencias	Líder técnico del escenario	EV-S02-B: propietario de módulo
Construcción y artefactos	Operaciones de prueba	EV-S02-C: cadena de entrega
Excepciones de riesgo	Comité simulado de seguridad	EV-S02-D: decisión

S02.03 Criterio general de evidencia

Una política propuesta, una configuración declarada y un resultado de prueba son categorías distintas. Los identificadores EV-S02-* solo nombran ejemplos; no existen capturas, registros ni reportes reales adjuntos. El estado base de esta sección es MODELO. Una respuesta RFP deberá describir el diseño hipotético sin afirmar que se ejecuta en todos los productos, instalaciones o equipos de una empresa real.

Cruces: gobierno jurídico en SYN-MON-LEGAL-ES L02, p. 3; evaluación de efectividad en SYN-MON-ISO-ES I08, p. 9.

Requisitos y modelado de amenazas

SYN-MON-SEC-ES | sección=S03 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=THREAT_MODEL; requisitos; abuso; confianza; banca

S03.01 Entrada de seguridad al diseño

En el modelo ficticio, cada cambio material incluiría inventario de datos, actores, permisos, interfaces, límites de confianza y supuestos de despliegue. Los requisitos distinguirían autenticación, autorización, integridad, disponibilidad y trazabilidad. La criticidad se elevaría si un cambio afectara transacciones, credenciales, administración o aislamiento entre clientes. No se asume que una función sea segura por estar dentro de una red privada.

S03.02 Amenazas específicas de la simulación

Para una instrucción bancaria sintética se analizarían repetición de solicitudes, alteración de beneficiario, salto de aprobación, doble procesamiento y acceso a objetos de otro cliente. La clave de idempotencia se vincularía al cliente, operación y contenido relevante, con tratamiento definido de reintentos. La aprobación de operaciones de prueba separaría al iniciador del aprobador cuando el requisito de negocio lo indique; no se afirma implementación de doble control en un producto real.

Amenaza ilustrativa	Requisito propuesto	Verificación de ejemplo
Acceso entre clientes	Autorizar sujeto, objeto y ámbito	Prueba negativa con otro tenant
Repetición de orden	Idempotencia y estado transaccional	Reintento con misma clave
Manipulación del importe	Validación del lado del servidor	Cambio posterior a aprobación
Filtración en errores	Mensajes sin datos o secretos	Revisión de respuestas y logs

S03.03 Salida y revisión del modelo

Cada amenaza conservaría impacto, probabilidad de ejemplo, mitigación, responsable y riesgo residual. El cierre exigiría evidencia de diseño y pruebas vinculadas al requisito. Un cambio de autenticación, dependencia crítica, arquitectura o acceso a datos reabrirla la revisión. Los diagramas y pruebas EV-S03-* son únicamente registros narrativos; no se presentan resultados de análisis sobre código real de Montran.

Estado: MODELO. Evidencia propuesta EV-S03-A: registro de amenazas; EV-S03-B: casos de abuso. Cruce: SYN-MON-ISO-ES I04, p. 5.

Identities, access and secrets

SYN-MON-SEC-ES | sección=S04 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=ACCESS; IAM; MFA; RBAC; secretos; privilegios

S04.01 Acceso humano en el modelo

Las cuentas ficticias serían individuales, con privilegio mínimo y autenticación multifactor para accesos administrativos, repositorios y plataforma de entrega. La autorización se revisaría cada trimestre y ante cambio de función. Un proceso de salida revocaría accesos al finalizar la relación del escenario. Ninguno de estos enunciados acredita configuraciones de identidad o mecanismos concretos implantados en Montran.

S04.02 Cuentas técnicas y credenciales

Las identidades de servicios se separarían de las humanas y se limitarían por entorno, función y recurso. Se propondrían credenciales de corta duración cuando el sistema lo admita. Los secretos no se almacenarían en código, imágenes, archivos de ejemplo ni registros. Un almacén de secretos del supuesto aplicaría permisos y auditoría; no se especifica un proveedor real ni una cuenta activa.

Situación ficticia	Acción propuesta	Evidencia narrativa
Alta privilegiada	Aprobación y duración definidas	EV-S04-A: autorización
Revisión trimestral	Retirar permisos no justificados	EV-S04-B: conciliación
Secreto expuesto	Revocar o rotar y evaluar uso	EV-S04-C: incidente
Acceso de emergencia	Justificar, caducar y revisar después	EV-S04-D: revisión

S04.03 Respuesta ante filtración y excepciones

Si el detector de ejemplo identificara una credencial válida, borrar la línea no bastaría: se revocaría el secreto, se revisaría su utilización y se evaluaría la propagación en historial y artefactos. Una excepción requeriría responsable, justificación, alcance, control compensatorio y caducidad. Un hallazgo que bloquea la entrega no se cerraría solo porque la cadena parezca un falso positivo; debería existir una validación documentada del supuesto.

Estado: MODELO. EV-S04-* no son registros de acceso reales. Tema relacionado: repositorios protegidos en S05 y respuesta a incidentes en S10.

Codificación y revisión de cambios

SYN-MON-SEC-ES | sección=S05 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=CODE_REVIEW; repositorios; ramas; validación; revisión

S05.01 Reglas de desarrollo del ejemplo

La guía ficticia propondría validación de entradas por tipo, tamaño y reglas del negocio; consultas parametrizadas; codificación de salidas según contexto; y autorización del lado del servidor. El manejo de errores evitaría exponer detalles internos. Las operaciones de prueba con efectos financieros usarían tipos decimales y reglas explícitas de redondeo y moneda. La interfaz de usuario no sería la única barrera para rechazar una operación no autorizada.

S05.02 Revisión antes de integración

Todo cambio del supuesto incluiría descripción, requisito, pruebas, dependencias y evaluación de seguridad. Las ramas de liberación se protegerían contra escritura directa y exigirían al menos una aprobación independiente. Un cambio material de autorización, criptografía o procesamiento de órdenes requeriría además revisión de seguridad. El autor podría explicar su solución, pero no reemplazar la revisión independiente con una autoaprobación.

Foco de revisión	Pregunta de control ficticia	Resultado esperado
Autorización	¿Se valida el permiso sobre cada objeto?	Casos positivos y negativos
Transacciones	¿Qué sucede con reintentos y concurrencia?	Integridad e idempotencia
Entradas y salidas	¿Se valida y codifica según contexto?	Sin confianza implícita
Observabilidad	¿Los eventos evitan datos y secretos?	Trazabilidad minimizada

S05.03 Cierre y cambios urgentes

Una observación de revisión conservaría su resolución y la evidencia asociada al cambio. La ruta urgente del modelo permitiría una aprobación excepcional documentada para recuperar servicio, con revisión posterior dentro de dos días hábiles. No eliminaría análisis de riesgo ni convertiría en aceptable un secreto expuesto. El historial EV-S05-A sería una ficha sintética de revisión, sin commits, repositorios o autores reales.

Estado: MODELO. Este documento no declara lenguajes, repositorios públicos, herramientas o prácticas reales de Montran. Cruce: requisitos de aceptación en SYN-MON-LEGAL-ES L03.

Pruebas y gestión de vulnerabilidades

SYN-MON-SEC-ES | sección=S06 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=VULNERABILITY; SAST; DAST; SCA; pentest; remediación

S06.01 Cobertura propuesta del programa

El escenario ficticio combinaría análisis estático, análisis de dependencias, detección de secretos y pruebas dinámicas en un entorno autorizado. Un cambio de alto riesgo incorporaría pruebas manuales basadas en amenazas. Un ensayo de penetración se planificaría antes de una liberación material y con periodicidad anual en el supuesto. No se afirma que se haya realizado ninguna prueba ni que un análisis automatizado garantice ausencia de vulnerabilidades.

Severidad ficticia	Contención / corrección objetivo	Decisión de liberación
Crítica	24 horas / 7 días calendario	Bloquear si es explotable
Alta	Según riesgo / 30 días calendario	Bloquear en alcance afectado
Media	Según riesgo / 90 días calendario	Plan con responsable
Baja	Según riesgo / 180 días calendario	Seguimiento priorizado

S06.02 Inicio del plazo y validación

Todos los plazos de corrección del cuadro son metas sintéticas desde la confirmación y clasificación del hallazgo. La contención crítica limita exposición y no equivale a reparación definitiva. La priorización considera explotabilidad, exposición, privilegios, datos e impacto de negocio, además de cualquier puntuación orientativa. Un falso positivo se cierra con justificación; un duplicado se vincula al registro principal sin perder su cobertura.

S06.03 Excepciones y nueva prueba

Una excepción hipotética podría durar como máximo 30 días calendario y exigiría aceptación explícita del riesgo, compensación, responsable y vencimiento. En este modelo no se admite excepción para un hallazgo crítico con explotación activa ni un secreto válido expuesto. La remediación se verificaría sobre la versión corregida y con prueba de regresión. Un reporte de escaneo sin revisión o un cambio de estado del ticket no demostrarían corrección.

EV-S06-A: registro inventado de hallazgos; EV-S06-B: nueva prueba propuesta. Estado: MODELO. Estos objetivos no son plazos legales o compromisos comerciales reales.

Dependencias y cadena de suministro

SYN-MON-SEC-ES | sección=S07 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=SUPPLY_CHAIN; SBOM; OSS; procedencia; dependencias

S07.01 Inventario y selección del supuesto

Cada entrega ficticia tendría una lista de componentes con nombre, versión, origen, identificador, licencia declarada y relación con el producto. Una SBOM de ejemplo se vincularía al artefacto exacto y a su huella, incluyendo dependencias transitivas cuando la herramienta de prueba pueda resolverlas. Si la cobertura es incompleta, el registro debe decirlo. La mera existencia de una lista no demuestra ausencia de código malicioso ni cumplimiento de licencias.

S07.02 Ingreso y actualización de componentes

La selección hipotética revisaría mantenimiento, procedencia, vulnerabilidades conocidas, permisos y obligaciones de licencia. Se fijarían versiones y se controlaría la resolución de paquetes para reducir sustitución involuntaria. Una actualización se evaluaría y probaría antes de liberar. Una dependencia obsoleta necesitaría plan de reemplazo o una excepción de riesgo; no se asumiría que el último número de versión es automáticamente adecuado.

Campo de SBOM sintética	Ejemplo de valor	Interpretación
Componente / versión	biblioteca-prueba / 0.0.1-demo	Nombre inventado; sin paquete real
Origen	repositorio-interno-de-prueba	Etiqueta; sin URL operativa
Licencia	PENDIENTE-DE-REVISIÓN	No implica autorización de uso
Huella de artefacto	NO-GENERADA-EN-ESTE-CORPUS	No existe binario adjunto

S07.03 Terceros y aviso de exposición

Ante un aviso de seguridad del supuesto, se identificarían productos, versiones y entornos afectados a partir del inventario. La ausencia del nombre en una lista incompleta no bastaría para descartar exposición. Se evaluaría si el componente vulnerable es alcanzable y cuál es el control compensatorio. Los registros EV-S07-* son descripciones ficticias y no constituyen una SBOM real, un análisis de licencias o un certificado de procedencia.

Estado: MODELO. Cruces: propiedad intelectual en SYN-MON-LEGAL-ES L04, terceros en L08 y aseguramiento de proveedores en SYN-MON-ISO-ES I08.

Construcción y liberación controlada

SYN-MON-SEC-ES | sección=S08 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=RELEASE; CI/CD; artefactos; firma; despliegue; rollback

S08.01 Cadena de entrega ficticia

La construcción propuesta partiría de una revisión identificada, dependencias fijadas y una configuración versionada. El entorno de construcción usaría permisos mínimos y aislamiento entre ejecuciones. Las credenciales de despliegue no estarían disponibles para tareas no confiables. La identidad del ejecutor, resultados de pruebas y aprobaciones se enlazarían con la versión. Esta descripción no identifica plataformas o integraciones utilizadas por Montran.

Puerta de control ficticia	Condición propuesta	Si no se satisface
Código revisado	Aprobación independiente y requisito	Devolver el cambio
Pruebas y análisis	Resultados revisados; bloqueos resueltos	Detener liberación
Artefacto identificado	Huella, versión y procedencia	Reconstruir o investigar
Despliegue autorizado	Plan, aprobación y reversión	Mantener versión anterior

S08.02 Integridad y promoción

En el supuesto se propone firmar o verificar criptográficamente artefactos según la capacidad del entorno. Las claves tendrían custodia y acceso restringidos. La promoción reutilizaría el mismo artefacto validado para reducir diferencias entre prueba y entrega. Firma, hash y SBOM son evidencias distintas: un archivo firmado podría contener una vulnerabilidad. No existen binarios, firmas, claves o atestaciones emitidas en este corpus.

S08.03 Reversión y emergencia

La liberación de ejemplo tendría comprobaciones posteriores y criterios para detener o revertir. Una migración de datos exigiría un plan específico; no se supondría que revertir el código revierte el estado de la base. La ruta urgente conservaría autorización, alcance y revisión posterior de dos días hábiles, conforme a S05. El cierre registraría versión desplegada, resultado y desviaciones; sin ejecución real, el estado permanece MODELO.

EV-S08-A: ficha ficticia de liberación; EV-S08-B: lista de puertas de control. Cruce: aceptación de entregables en SYN-MON-LEGAL-ES L03 y calidad en SYN-MON-ISO-ES I06.

Protección de datos y trazabilidad

SYN-MON-SEC-ES | sección=S09 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=DATA_PROTECTION; cifrado; registros; retención; aislamiento

S09.01 Datos, aislamiento y cifrado del modelo

Las pruebas ficticias usarían datos generados y evitarían copiar información real de producción. El diseño propondría cifrado de transporte y de almacenamiento mediante configuraciones evaluadas por el responsable técnico, sin afirmar algoritmos o servicios reales. El acceso a claves se separaría del acceso a datos. El aislamiento entre clientes se verificaría en consultas, archivos, cachés, exportaciones y tareas asíncronas; no solo en la interfaz.

Objeto del escenario	Conservación sintética	Condición de protección
Registros operativos	180 días	Sin secretos ni datos completos innecesarios
Copias de respaldo	35 días desde creación	Acceso limitado; no uso ordinario
Datos activos al cierre	Eliminar hasta 30 días calendario	Desde fecha de cierre aprobada
Exportación de salida	10 días hábiles	Desde solicitud validada; entrega autorizada

S09.02 Eventos y calidad de los registros

Un evento de ejemplo contendría marca de tiempo consistente, identificador de correlación, actor, acción, objeto y resultado. Los identificadores sensibles se minimizarían. Se probarían integridad del transporte, acceso restringido, consulta y manejo de interrupciones. La falta de un evento no demostraría que una acción no ocurrió: puede existir pérdida o cobertura incompleta. No se incorporan registros de actividad reales en esta muestra.

S09.03 Eliminación y excepciones de conservación

El cierre del supuesto impediría nuevas copias después de la fecha aprobada. Los respaldos existentes caducarían por edad, con máximo residual de 35 días si la última copia se creó al cierre. Una conservación excepcional autorizada afectaría solo al subconjunto registrado y tendría revisión. El procedimiento de borrado registraría alcance y comprobación; este PDF no es una constancia de eliminación ni prueba de residencia de datos.

Estado: MODELO / CONDICIONADO al alcance. Cruces: privacidad y salida en SYN-MON-LEGAL-ES L05 y L09. No consta localización real de infraestructura.

Incidentes, recuperación y mejora

SYN-MON-SEC-ES | sección=S10 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=INCIDENT; respuesta; continuidad; RTO; RPO; ejercicios

S10.01 Flujo de respuesta del supuesto

El proceso ficticio registraría recepción, detección, análisis, confirmación, contención, recuperación y lecciones aprendidas. Se evaluaría el impacto en datos, integridad transaccional, disponibilidad y terceros. El responsable conservaría evidencia pertinente y separaría hechos, hipótesis y acciones. Una vulnerabilidad sin explotación demostrada no se etiquetaría automáticamente como incidente confirmado, aunque podría requerir tratamiento urgente.

Reloj o meta del modelo	Valor sintético	Significado
Acuse de soporte P1	30 minutos corridos; 24x7	Desde registro válido del caso
Aviso inicial al cliente	24 horas corridas	Desde confirmación del incidente
RTO de continuidad	4 horas	Desde activación del escenario de recuperación
RPO de continuidad	15 minutos	Antigüedad máxima objetivo de datos recuperables

S10.02 Restauración y comunicaciones

El aviso inicial de ejemplo comunicaría impacto conocido, medidas, incertidumbres y próximo punto de actualización; no esperaría necesariamente a la causa raíz completa. El objetivo RTO es específico del escenario ficticio de activación y no una promesa de restauración desde cualquier señal inicial. Recuperar un respaldo exigiría validar integridad, consistencia y capacidad del servicio, además de comprobar que la amenaza no persiste.

S10.03 Ejercicio y cierre del modelo

Se propondría un ejercicio anual y después de cambios materiales, con alcance, participantes ficticios, supuestos, tiempos observados y acciones. RTO y RPO no se declararían alcanzados sin resultados. Una revisión posterior podría revelar diferencias entre el plan y la capacidad de restauración. En este corpus no existen pruebas de recuperación ejecutadas ni informes de incidentes reales; EV-S10-A identifica solo un guion de simulación.

Estado: MODELO. Cruces: SYN-MON-LEGAL-ES L06, p. 7; SYN-MON-ISO-ES I07, p. 8. Plazos legales de notificación: NO CONSTA.

Matriz RFP: diseño y desarrollo

SYN-MON-SEC-ES | sección=S11 | idioma=es | versión=1.0 | fictional=true

Etiquetas: topic_id=RFP_SEC_A; SSDLC; revisión; pruebas; evidencia

Respuestas ficticias para pruebas de recuperación. No usar estas filas como afirmación de controles implementados en una organización real.

ID / pregunta de prueba	Respuesta modelo y condición	Localizador / estado
RFP-S01 ¿Existe un ciclo de desarrollo seguro?	El corpus propone un ciclo con requisitos, amenazas, revisión, pruebas y aprobación. No documenta su operación real.	S02-S08, pp. 3-9 MODELO
RFP-S02 ¿Cómo se evalúan riesgos bancarios?	El ejemplo revisa repetición, doble procesamiento, alteración de importes y acceso entre clientes, con requisitos y pruebas negativas.	S03, p. 4 MODELO
RFP-S03 ¿Se usa MFA y privilegio mínimo?	El diseño ficticio los propone para accesos administrativos, repositorios y entrega, con revisión trimestral de permisos.	S04.01, p. 5 MODELO
RFP-S04 ¿Se revisan todos los cambios?	El modelo exige una aprobación independiente y revisión adicional de seguridad para cambios materiales de alto riesgo.	S05.02, p. 6 MODELO
RFP-S05 ¿Qué análisis se realizan?	Se proponen análisis estático, dinámico, de dependencias y secretos, más pruebas manuales según riesgo. No hay reportes ejecutados.	S06.01, p. 7 MODELO
RFP-S06 ¿Hay una SBOM de cada entrega?	El modelo la propone por artefacto con cobertura declarada. Este corpus no adjunta una SBOM ni un binario real.	S07, p. 8 MODELO

S11.01 Regla para evaluar respuestas afirmativas

La frase «el modelo propone» conserva el estatus de diseño. Una respuesta que diga «Montran implementa estos controles» excede la evidencia disponible y debe fallar el ensayo. Si se solicita nombre de herramienta, lenguaje, repositorio, proveedor de identidad o informe de penetración real, la salida correcta es «No consta en este corpus ficticio». No completar esos campos con marcas conocidas.

Metadatos por fila: doc_id=SYN-MON-SEC-ES; section_id=S11; chunk_id=RFP-S01...RFP-S06; fictional=true; evidence_type=synthetic_narrative.

Matriz RFP: operación y remediación

SYN-MON-SEC-ES | sección=S12 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=RFP_SEC_B; SLA; vulnerabilidades; incidentes; continuidad

Los valores numéricos son parámetros sintéticos del escenario. Deben recuperarse junto con su alcance, reloj y condiciones.

ID / pregunta de prueba	Respuesta modelo y condición	Localizador / estado
RFP-S07 ¿Cuándo se corrige un hallazgo crítico?	Meta ficticia: contención en 24 horas y corrección en siete días calendario desde confirmación y clasificación.	S06, p. 7 MODELO
RFP-S08 ¿Se admiten excepciones de seguridad?	El modelo admite excepciones por hasta 30 días, salvo crítica con explotación activa o secreto válido expuesto. Requiere aceptación.	S06.03, p. 7 CONDICIONADO
RFP-S09 ¿Cómo se controla una liberación?	El diseño exige revisión, análisis revisados, artefacto identificado y despliegue autorizado con reversión planificada.	S08, p. 9 MODELO
RFP-S10 ¿Cuánto se retienen registros y copias?	En el supuesto: registros operativos por 180 días y copias por 35 días desde creación; sin nuevas copias después del cierre.	S09, p. 10 MODELO
RFP-S11 ¿Cuándo se avisa un incidente?	Aviso inicial en 24 horas corridas desde confirmación; es distinto del acuse de soporte P1 de 30 minutos.	S10, p. 11 MODELO
RFP-S12 ¿Se garantizan RTO y RPO?	Solo se proponen RTO de cuatro horas desde activación y RPO de 15 minutos. No hay evidencia de ensayo o garantía real.	S10.02-03, p. 11 NO CONSTA ejecución

S12.01 Lectura conjunta de plazos

Los 24 de contención crítica y los 24 de aviso de incidente coinciden numéricamente pero responden a eventos distintos. S06 mide hallazgos confirmados y clasificados; S10 mide incidentes confirmados. Treinta días de excepción no son el plazo de corrección de todo hallazgo. Una respuesta completa conserva severidad, tipo de acción, condición de inicio y unidad temporal del dato solicitado.

Metadatos por fila: doc_id=SYN-MON-SEC-ES; section_id=S12; chunk_id=RFP-S07...RFP-S12; fictional=true; evidence_type=synthetic_narrative.

Pruebas RAG/CAG y evidencia ausente

SYN-MON-SEC-ES | sección=S13 | idioma=es | versión=1.0 | fictional=true
Etiquetas: topic_id=EVAL_SEC; retrieval; caché; abstención; controles

S13.01 Registro de recuperación de ejemplo

doc_id=SYN-MON-SEC-ES; version=1.0; section_id=S12; chunk_id=RFP-S07; page=13; language=es; topic_id=VULNERABILITY; fictional=true; source_section=S06; source_page=7. Para una fila RFP se conserva el localizador de la propia fila y el de su fundamento. No tratar una descripción EV-* como enlace a un archivo disponible ni como evidencia emitida por una herramienta.

Consulta de evaluación	Respuesta esperada del ejemplo	Fuente
¿En qué repositorio está el código de Montran?	No consta repositorio real. El corpus define prácticas hipotéticas sin direcciones operativas.	S02 / S05
¿Se corrige una vulnerabilidad crítica en 24 horas?	No: 24 horas es contención; la corrección objetivo es siete días calendario. Ambas son metas ficticias.	S06
¿Un artefacto firmado no tiene vulnerabilidades?	No se deduce; firma, análisis y revisión aportan evidencias diferentes en el modelo.	S08.02
¿Se puede exceptuar un secreto válido expuesto?	En este modelo no se admite esa excepción de liberación; se revoca o rota y se evalúa el uso.	S04 / S06
¿Se alcanzó RPO de 15 minutos en una prueba?	No consta una prueba ejecutada; solo se define el objetivo sintético.	S10.03

S13.02 Segmentación y evaluación

Usar como ensayo fragmentos de 350 a 650 tokens, preservando filas y calificadores. Añadir a cada fragmento el estado ficticio, la versión y las etiquetas del tema. En CAG, invalidar un bloque si cambia la versión o se corrige un plazo. La evidencia de aprobación del ensayo debería revisar exactitud de valores, citas, distinción entre diseño y ejecución y abstención sobre atributos reales desconocidos.

S13.03 Cobertura deliberadamente limitada

No constan arquitectura real, lenguajes, herramientas, algoritmos configurados, informes de pruebas, personal, incidentes, defectos de productos ni controles de Montran. Tampoco consta conformidad con normas o leyes. La narrativa sirve para ensayar preguntas técnicas y respuestas condicionadas. Las referencias al documento ISO son cruces internos del corpus y no constituyen aval independiente de esta política.